

Etica, Società e Privacy

Risposte alle Domande d'Esame Più Frequenti

Università di Torino – Magistrale Informatica – A.A. 2024/2025

Indice

1	Differential Privacy	3
2	Local e Global Differential Privacy	3
3	Privacy e Security	4
4	Privacy: Perché è Importante?	5
5	GDPR: Principi e Sanzioni	6
6	Discriminazione (Fairness)	7
7	Teoremi di Incompatibilità: Separazione e Sufficienza	8
8	Algoritmi per la K-Anonymity: Samarati e Incognito	9
9	Laplace e Gauss (per Numerici), Esponenziale (per Categoricali)	10
10	Bias per Discriminazione e Apprendimento (Fairness)	10
11	Trade-off Privacy-Utilità. KL e JS	11
12	Uso di XML per RBAC e ABAC	12
13	Privacy by Design e by Default	13
14	Cambridge Analytica	13
15	Principi Crittografici nel Corso	14
16	L-Diversity e Differential Privacy	16
17	Multiparty Secure Computation: Milionari, OT, ID3	16
18	Bias: Rischi Etici e Misurazione (Fairness)	18

Introduzione

Questo documento risponde alle 22 domande d'esame più frequentemente poste nel corso di Etica, Società e Privacy (modulo Privacy) presso l'Università di Torino.

1 Differential Privacy

Domanda 1: Differential Privacy

Cos'è la Differential Privacy? Spiegare la definizione formale, la motivazione e come funziona.

La **Differential Privacy (DP)**, introdotta da Cynthia Dwork nel 2006 ("Calibrating Noise to Sensitivity in Private Data Analysis"), è un framework matematico rigoroso per rilasciare informazioni statistiche proteggendo contemporaneamente la privacy degli individui nel dataset.

Motivazione: vogliamo poter rispondere a query su un dataset senza rivelare informazioni sugli individui specifici. La DP garantisce che la presenza o l'assenza di un singolo individuo nel dataset abbia un impatto trascurabile sull'output della query.

Definizione formale: Due dataset D e D' si dicono *adiacenti* ($D \sim D'$) se differiscono per esattamente un record. Un meccanismo randomizzato $\mathcal{M} : \Omega \times Q \rightarrow \mathcal{R}$ preserva la ε -differential privacy se per qualsiasi query q , per ogni coppia di dataset adiacenti D, D' e per ogni possibile risposta $r \in \mathcal{R}$:

$$e^{-\varepsilon} \leq \frac{\mathbb{P}(\mathcal{M}(q, D) = r)}{\mathbb{P}(\mathcal{M}(q, D') = r)} \leq e^{\varepsilon}$$

Privacy budget ε : più piccolo è ε , maggiore è la garanzia di privacy; per $\varepsilon \rightarrow 0$ le due distribuzioni sono indistinguibili (massima privacy, minima utilità). Valori tipici: $\varepsilon \in [0.1, 5]$.

Meccanismo di Laplace: il principale meccanismo per query numeriche. Aggiunge rumore Laplaciano calibrato alla sensibilità della query:

$$\mathcal{M}_{Lap}(D, q) = q(D) + Lap\left(0, \frac{GS_1(q)}{\varepsilon}\right)$$

dove $GS_1(q) = \max_{D \sim D'} |q(D) - q(D')|$ è la *sensibilità globale* (il massimo cambiamento possibile dell'output togliendo/aggiungendo un record).

Teoremi fondamentali:

- **Post-processing:** qualunque elaborazione dell'output di un meccanismo DP non riduce la privacy.
- **Composizione:** due meccanismi ε_1 -DP e ε_2 -DP composti danno $(\varepsilon_1 + \varepsilon_2)$ -DP.
- **Composizione parallela:** applicare lo stesso meccanismo ε -DP su partizioni disgiunte del dataset mantiene ε -DP.

La DP offre una **garanzia matematicamente dimostrabile** contro qualsiasi forma di disclosure, indipendentemente dalla conoscenza pregressa dell'avversario.

2 Local e Global Differential Privacy

Domanda 2 & 9: Local e Global Differential Privacy

Qual è la differenza tra Local e Global Differential Privacy?

Global Differential Privacy (GDP) / Standard DP:

- Esiste un **curatore fidato** (trusted curator) che raccoglie i dati grezzi di tutti gli individui.
- La randomizzazione avviene *sul database aggregato* prima di rispondere alle query.
- L'indistinguibilità riguarda **dataset adiacenti** (differiscono per un solo record).

- Richiede meno rumore $\Rightarrow$ maggiore utilità.
- Esempio: il curatore raccoglie tutti i dati medici e risponde alle query aggiungendo rumore.

Local Differential Privacy (LDP):

- **Non c'è un curatore fidato.** Ogni individuo randomizza i propri dati *prima* di inviarli al raccoglitore.
- L'indistinguibilità riguarda **qualsiasi coppia di record** $x, x' \in U$ (non solo dataset adiacenti):

$$\mathbb{P}(\mathcal{M}(q, x) = r) \leq e^\epsilon \cdot \mathbb{P}(\mathcal{M}(q, x') = r) + \delta$$

- Richiede **molto più rumore** $\Rightarrow$ minore utilità.
- Esempio: Randomized Response, Apple (iOS), Google (Chrome Rappor).

Aspetto	GDP	LDP
Fiducia nel curatore	Sì	No
Dove si randomizza	Sul database	Sui singoli record
Indistinguibilità	Dataset adiacenti	Qualsiasi coppia di record
Quantità di rumore	Minore	Maggiore
Utilità	Maggiore	Minore

Randomized Response (LDP, Warner 1965): tecnica classica per sondaggi sensibili.

1. Lancia una moneta.
2. Testa: rispondi veridicamente.
3. Croce: lancia di nuovo e rispondi Sì/No in modo casuale.

$P(\text{Sì}|\text{vero}=\text{Sì}) = 3/4$, $P(\text{Sì}|\text{vero}=\text{No}) = 1/4$. Rapporto massimo: $\frac{3/4}{1/4} = 3 = e^{\log 3} \Rightarrow$ preserva $\log(3)$ -LDP.

Randomized Response Generalizzato per k categorie: $P(\mathcal{M}(x) = v) = \frac{e^\epsilon}{e^\epsilon + k - 1}$ se $v = q(x)$, altrimenti $\frac{1}{e^\epsilon + k - 1}$.

3 Privacy e Security

Domanda 3: Privacy e Security

Qual è la relazione tra Privacy e Security?

Privacy e **Security** sono concetti correlati ma distinti:

Security (Sicurezza):

- Riguarda la **protezione dei dati da accessi non autorizzati**.
- Si occupa di garantire: *confidenzialità* (solo chi è autorizzato accede), *integrità* (i dati non vengono alterati), *disponibilità* (i dati sono accessibili quando necessario).
- Strumenti: crittografia, firewall, autenticazione, controllo degli accessi (RBAC, ABAC).
- Focus: **proteggere il sistema** dagli attaccanti.

Privacy:

- Riguarda il **controllo sull'uso delle informazioni personali**, anche da parte di chi ha accesso autorizzato.
- Si occupa di: uso appropriato dei dati, consenso, minimizzazione, anonimizzazione.
- Strumenti: k-anonymity, differential privacy, pseudonimizzazione, SDC.
- Focus: **proteggere gli individui** da un uso improprio dei loro dati.

Relazione: la security è *necessaria ma non sufficiente* per la privacy.

- Un sistema può essere sicuro ma violare la privacy (es. un ospedale che ha la sicurezza delle reti ma vende i dati dei pazienti).
- La privacy richiede la security come fondamento, ma va oltre.

Nel contesto del GDPR, entrambe sono richieste: il controllore deve implementare misure di sicurezza adeguate (Art. 32) e rispettare i principi di Privacy by Design e by Default (Art. 25).

La crittografia su colonne, il Randomized Response e i sistemi di controllo degli accessi (ABAC/RBAC) sono strumenti che servono sia la security che la privacy.

4 Privacy: Perché è Importante?

Domanda 4: Privacy: perché è importante?

Spiegare perché la privacy è importante, con riferimento a fonti teoriche e casi concreti.

La privacy è importante per molteplici ragioni:

1. Sentimenti individuali e dignità: La perdita della privacy crea un senso di disagio (“non confortabile”). I dati possono essere usati in modo improprio (furto d'identità). Stefano Rodatà lega la privacy alla **dignità umana**: la perdita dei dati personali ha un costo immenso (1.000–3.000\$ per cittadino).

2. Esigenze aziendali: Le aziende devono proteggere la reputazione, far sentire i clienti al sicuro, evitare dispute legali e rispettare le leggi.

3. Libertà civile e democrazia: Come dice Edward Snowden: *“Argomentare che non ci importa della privacy perché non abbiamo nulla da nascondere è come dire che non ci importa della libertà di espressione perché non abbiamo nulla da dire.”*

4. Evidenza empirica – casi concreti:

- **Netflix Prize (2006):** dati di rating “anonimizzati” re-identificati con probabilità 90%.
- **AOL (2006):** query di ricerca “anonimizzate” permettono di identificare gli utenti.
- **Cambridge Analytica (2018):** dati di 87 milioni di utenti Facebook usati per manipolare elezioni politiche.
- **Studio PNAS 2013:** i “Like” di Facebook rivelano orientamento sessuale, opinioni politiche, salute.
- **Sweeney (2001):** l'87% degli americani è unicamente identificabile da {ZIP, sesso, data di nascita}.
- **INPS data breach (2020):** hackers italiani accedono ai dati dell'INPS durante la pandemia.

5. Trade-off privacy-comodità: Più comodità spesso significa meno privacy (GPS, cookies, social network). Ma questo trade-off è in parte frutto di **ignoranza e conformismo**: con le tecniche giuste (DP, k-anonymity) è possibile ottenere sia utilità dei dati che protezione della privacy.

5 GDPR: Princìpi e Sanzioni

Domanda 5 & 14: GDPR – Princìpi, Sanzioni e Novità rispetto alla Direttiva

Descrivere il GDPR: princìpi fondamentali, sanzioni, novità rispetto alla Direttiva 95/46/EC, differenze con paesi extra-UE (USA).

Il **GDPR** (Regolamento EU 2016/679) è un **regolamento** (non direttiva) adottato il 27 aprile 2016, applicabile dal 25 maggio 2018. Non richiede leggi nazionali di recepimento.

Princìpi fondamentali (ereditati e rafforzati dalla Direttiva):

1. **Trasparenza:** il soggetto deve dare *consenso chiaro ed esplicito*; ha diritto di accedere facilmente ai propri dati.
2. **Scopo Legittimo:** i dati possono essere trattati solo per scopi specificati e non ulteriormente elaborati in modo incompatibile.
3. **Proporzionalità:** i dati devono essere accurati, aggiornati, e non mantenuti più del necessario.

Novità del GDPR rispetto alla Direttiva 95/46/EC:

- **Nuovi diritti:** diritto all'oblio (right to be forgotten), portabilità dei dati, diritto di opporsi al profiling.
- **Definizioni ampliate:** “dati personali” ora include location data, online identifier, dati genetici.
- “Trattamento” ora include structuring (strutturazione) e restriction (limitazione).
- **Pseudonimizzazione:** definita esplicitamente; se adeguata $\Rightarrow$ dati non soggetti a GDPR.
- **Privacy by Design e by Default:** obbligo formale (Art. 25).
- **Data Protection Officer (DPO):** figura obbligatoria per certi tipi di organizzazioni.
- **Data Protection Impact Assessment (DPIA):** obbligatorio per trattamenti ad alto rischio.
- **Data breach notification:** entro 72 ore all'autorità di supervisione.
- **Sanzioni molto più severe:** fino al 4% del fatturato mondiale.
- **Regolamento direttamente applicabile:** nessuna legge di recepimento nazionale necessaria.

Sanzioni GDPR:

- Prima violazione non intenzionale: **avviso**.
- Violazione di obblighi minori: fino a **10 milioni di euro** o **2% del fatturato mondiale**.
- Violazione grave dei princìpi: fino a **20 milioni di euro** o **4% del fatturato mondiale**.

Differenze EU vs. USA:

- Negli USA **non esiste una legge unificata** sulla data privacy: HIPAA (sanità), COPPA (minori), FCRA (credito), ECPA (comunicazioni), PATRIOT Act (sorveglianza). Le aziende che raccolgono dati (anche senza consenso) hanno il diritto di usarli.

- In UE la privacy è un **diritto fondamentale** (ECHR Art.8); il GDPR si applica a tutte le organizzazioni che trattano dati di cittadini UE, ovunque nel mondo.
- Accordi transatlantici per trasferimento dati: Safe Harbor (1998–2015) → EU-US Privacy Shield (2016–2020) → EU-US Data Privacy Framework (2023).

L'AI Act (2024): complementare al GDPR, classifica i sistemi di IA in 4 livelli di rischio (inaccettabile, alto, limitato, minimo).

6 Discriminazione (Fairness)

Domanda 6: Discriminazione (parte su Fairness)

Cos'è la discriminazione? Che tipi esistono? Come si relaziona con i sistemi algoritmici?

Definizione: Discriminazione Diretta

La pratica di trattare in modo **diverso** le persone in base alla loro appartenenza a un gruppo sociale rilevante (razza, genere, religione, orientamento sessuale, età, etc.). Nell'UE è disciplinata dall'Art. 21 della Carta dei Diritti Fondamentali.

Definizione: Discriminazione Indiretta

La pratica di offrire lo **stesso trattamento** a persone appartenenti a gruppi distinti, quando questo comporta che un gruppo sia posto in una situazione di particolare svantaggio.

Esempi:

- *Discriminazione indiretta:* le pensioni calcolate ugualmente per part-time e full-time penalizzano le donne (88% dei part-time) ⇒ effetto sproporzionatamente negativo (caso Hilde Schönheit vs. Stadt Frankfurt am Main).
- *Discriminazione indiretta sistemica:* test di intelligenza standardizzati per studenti Rom in Repubblica Ceca, concepiti per la popolazione generale ceca ⇒ 50-90% dei bambini Rom fuori dal sistema scolastico tradizionale (caso D.H. vs. Repubblica Ceca).

Cosa rende sbagliata la discriminazione?

1. *Animosità sistematica (intento ostile):* tradizionalmente la base per definire la discriminazione. Ma: gli algoritmi non hanno intenzioni; gli scienziati possono affermare di non aver avuto intenzioni discriminatorie.
2. *Fare inferenze sugli individui basate sui gruppi:* trattare le persone come rappresentanti di categorie invece che come individui.

Discriminazione algoritmica: i sistemi ML ereditano (e amplificano) i bias presenti nei dati di training.

- Google Photos classifica afroamericani come gorilla.
- COMPAS: sistema di predizione della recidiva criminale assegna punteggi di rischio più alti ad afroamericani.
- Amazon recruitment model: discrimina le donne (le candidature con curricula femminili ricevono punteggi minori).

- Negli USA, candidati con nomi “bianchi” ricevono il 50% in più di colloqui di lavoro.

Tipi di danni algoritmici:

- **Allocativi:** risorse negate disparatamente (prestiti, assunzioni, libertà provvisoria).
- **Rappresentativi:** subordinazione rafforzata (ricerca di immagini, traduzione automatica).

7 Teoremi di Incompatibilità: Separazione e Sufficienza

Domanda 7: Teoremi di Incompatibilità: Separazione e Sufficienza

Enunciare e spiegare i teoremi di incompatibilità tra i criteri di fairness.

Siano X covariate, Y variabile target (ground truth), $\hat{Y}$ predizione del classificatore, A attributo sensibile (es. razza, genere).

Tre criteri principali di fairness:

1. **Indipendenza (Demographic Parity):** $\hat{Y} \perp A$

$$\mathbb{P}(\hat{Y} = 1 \mid A = a) = \mathbb{P}(\hat{Y} = 1 \mid A = b)$$

Ogni gruppo riceve la stessa percentuale di esiti positivi.

2. **Separazione (Equal Error Rates):** $\hat{Y} \perp A \mid Y$

Il classificatore commette errori con la stessa frequenza nei vari gruppi. Può essere intesa come parità dei tassi di errore tra i gruppi.

3. **Sufficienza (Calibration):** $Y \perp A \mid \hat{Y}$

La previsione del modello è ugualmente affidabile (calibrata) per tutti i gruppi.

Teoremi di Incompatibilità:

Teorema di Impossibilità (Chouldechova, 2017; Kleinberg et al., 2016)

Se A e Y non sono indipendenti (cioè il tasso base ($P(Y = 1)$) differisce tra i gruppi), allora:

1. **Separazione e Indipendenza non possono essere entrambe soddisfatte** simultaneamente (eccetto in casi degeneri).
2. **Sufficienza e Indipendenza non possono essere entrambe soddisfatte** simultaneamente (eccetto in casi degeneri).

Interpretazione intuitiva: Se il tasso base è diverso tra i gruppi (es. il gruppo A ha storicamente più recidiva del gruppo B), allora un classificatore calibrato avrà necessariamente tassi di errore diversi tra i gruppi (viola separazione), e viceversa.

Implicazione pratica: Non esiste un classificatore “perfetto” in termini di fairness quando i gruppi hanno tassi base diversi. Bisogna scegliere quale criterio privilegiare in base al contesto etico e legale.

Esempio COMPAS: un sistema calibrato (sufficienza: la previsione ha lo stesso significato per bianchi e neri) avrà necessariamente tassi di falsi positivi diversi tra i gruppi se i tassi di recidiva base sono diversi (viola separazione). Non è possibile avere entrambi.

Interventi di fairness:

- **Pre-processing:** modificare i dati di input X o i target Y .
- **In-processing:** vincoli o penalizzazioni durante il training.
- **Post-processing:** modificare $\hat{Y}$ dopo il training.

8 Algoritmi per la K-Anonymity: Samarati e Incognito

Domanda 8 & 20: K-Anonymity e Algoritmi

Definire la k -anonymity e descrivere gli algoritmi di Samarati e Incognito.

Il problema: Latanya Sweeney (2001) re-identifica record medici del governatore del Massachusetts incrociando dati medici anonimizzati con la lista elettorale usando {ZIP code, sesso, data di nascita} come quasi-identificatori. L'87% degli americani è unicamente identificabile da questi tre attributi.

Definizione: K-Anonymity – Samarati & Sweeney, 1998

Un dataset T su attributi $A = a_1, \dots, a_n$ soddisfa la k -anonymity se e solo se per ogni combinazione di valori di quasi-identificatori in T , tale combinazione appare almeno k volte. Ogni individuo si nasconde in $k - 1$ altri individui; la confidenza di un linking attack è $\leq 1/k$.

Tecniche:

- **Generalizzazione:** valori sostituiti con valori più generali (ZIP 10149 $\rightarrow$ 101 * *).
- **Soppressione:** rimozione di tuple outlier che non possono essere generalizzate.

Domain Generalization Hierarchy (DGH): ordine parziale sui domini di un attributo. Il prodotto cartesiano di tutte le DGH forma un **reticolo di generalizzazione**.

Il problema di trovare la generalizzazione minimale è **NP-hard**.

Algoritmo di Samarati: Effettua una **ricerca binaria** sull'altezza del reticolo:

1. Valuta tutte le soluzioni ad altezza $h/2$.
2. Se esiste almeno una soluzione k -anonima: scendi a $h/4$; altrimenti sali a $3h/4$.
3. Ripeti fino a trovare l'altezza minima con una soluzione k -anonima con $\leq \text{MaxSup}$ soppressioni.

Proprietà: salendo nella gerarchia il numero di soppressioni necessarie diminuisce. Approccio branch-and-bound.

Algoritmo Incognito: Sfrutta la **monotonicità** della k -anonymity: se $QI' \subseteq QI$, la k -anonymity su QI' è condizione necessaria per la k -anonymity su QI .

Approccio **bottom-up** nel reticolo:

1. Iterazione 1: controlla la k -anonymity per ogni singolo attributo in QI ; scarta le generalizzazioni che non la soddisfano.
2. Iterazione 2: combina i rimanenti in coppie e controlla.
3. Iterazione i : combina tutte le i -uple.
4. Iterazione $|QI|$: risultato finale.

Limitazioni della k -anonymity:

- **Homogeneity attack:** se tutte le tuple in un blocco hanno lo stesso valore sensibile, la k -anonymity non protegge.
- **Background knowledge attack:** la conoscenza pregressa permette di inferire informazioni.
- **Curse of Dimensionality** (Aggarwal, VLDB 2005): con molti quasi-identificatori la k -anonymity richiede una generalizzazione eccessiva.

9 Laplace e Gauss (per Numerici), Esponenziale (per Categorici)

Domanda 10: Meccanismi Laplace, Gauss, Esponenziale

Descrivere i meccanismi di Laplace, Gaussiano ed Esponenziale per la Differential Privacy.

Meccanismo di Laplace (per query numeriche, ϵ -DP):

$$\mathcal{M}_{Lap}(D, q) = q(D) + Lap\left(0, \frac{GS_1(q)}{\epsilon}\right)$$

$GS_1(q) = \max_{D \sim D'} \|q(D) - q(D')\|_1$ (sensibilità L1). PDF: $f(x) = \frac{\epsilon}{2GS_1} e^{-\epsilon|x-q(D)|/GS_1}$.

Proprietà: Preserva ϵ -DP per qualsiasi $\epsilon > 0$. Meno rumore (migliore utilità) quando la sensibilità L1 è piccola. Ideale per query scalari e vettoriali con $GS_2 \approx GS_1$.

Meccanismo Gaussiano (per query vettoriali, (ϵ, δ) -DP):

$$\mathcal{M}_{Gauss}(D, q) = q(D) + \mathcal{N}(0, \sigma^2), \quad \sigma^2 = \frac{2 \cdot GS_2(q)^2 \cdot \ln(1.25/\delta)}{\epsilon^2}$$

$GS_2(q) = \max_{D \sim D'} \|q(D) - q(D')\|_2$ (sensibilità L2). Preserva (ϵ, δ) -DP per $\epsilon, \delta \in (0, 1)$.

Confronto Laplace vs. Gaussiano:

Aspetto	Laplace	Gaussiano
Tipo di DP	ϵ -DP	(ϵ, δ) -DP
Sensibilità	L1 (GS_1)	L2 (GS_2)
Vincolo su ϵ	Qualsiasi $\epsilon > 0$	Richiede $\epsilon < 1$
Quando preferire	Sempre disponibile	$GS_2 \ll GS_1$ (query ad alta dimensione)

Entropia: Gaussiano ha $H = \frac{1}{2} \log(2\pi e \sigma^2)$; Laplace ha $H = \ln(\sqrt{2}e\sigma)$. Il Gaussiano ha entropia minore (meno rumore) a parità di σ .

Meccanismo Esponenziale (per query categoriche):

Per query il cui output è un elemento r da un insieme categorico R (es. selezionare il candidato migliore), dove non ha senso aggiungere rumore numerico.

Sia $U : \Omega \times R \rightarrow \mathbb{R}$ una funzione di utilità e $GS(U) = \max_{r, D \sim D'} |U(D, r) - U(D', r)|$.

$$P(\mathcal{M}(D, q) = r) \propto \exp\left(\frac{\epsilon \cdot U(D, r)}{2 \cdot GS(U)}\right)$$

L'output più utile viene selezionato con probabilità proporzionalmente più alta; preserva la DP con parametro $\epsilon/2$ (o ϵ a seconda della formulazione).

10 Bias per Discriminazione e Apprendimento (Fairness)

Domanda 11: Concetto di Bias per Discriminazione e Apprendimento

Cos'è il bias in ML? Come si manifesta e perché porta alla discriminazione?

Bias nel Machine Learning: tendenza sistematica del modello a produrre errori sistematici in favore o contro certi gruppi.

Fonti di bias nel ciclo ML:

1. Bias nei dati di training (data bias):

- *Historical bias*: i dati riflettono pregiudizi storici (es. le donne erano sottorappresentate nei curricula di ingegneria).
- *Representation bias*: alcuni gruppi sono sottorappresentati nel dataset (insufficienti dati per certe etnie).
- *Measurement bias*: le misurazioni stesse sono parziali (es. lo stesso reato è registrato diversamente per diverse etnie).

2. Bias nell'apprendimento:

- *Inductive bias*: le assunzioni dell'algoritmo di learning (es. linearità) possono non adattarsi ugualmente bene a tutti i gruppi.
- Il modello può imparare correlazioni spurie tra attributi innocui e attributi sensibili (*proxy attributes*).

3. Bias nel deployment:

- Le azioni del modello cambiano il mondo (feedback loop): un modello che discrimina può creare dati futuri che confermano la discriminazione (self-fulfilling prophecy).

Problema dell'opacità: L'IA attuariale (ML) è spesso opaca – è difficile capire perché un sistema ha preso una particolare decisione. Anche ispezionando i parametri, è difficile collegare questi alle ragioni effettive delle decisioni.

Il paradosso dell'inconsapevolezza: Non usare esplicitamente l'attributo sensibile A (etnia, genere) non garantisce fairness, perché altri attributi possono essere fortemente correlati con A e il modello li userà implicitamente come proxy.

Esempi di bias algoritmico:

- COMPAS: bias razziale nei punteggi di rischio di recidiva.
- Amazon recruitment: downgrade dei curricula con parole associate alle donne.
- Riconoscimento facciale: errori più frequenti per donne e persone di colore.
- Traduzione automatica (Google Translate): introduce stereotipi di genere.

11 Trade-off Privacy-Utilità. KL e JS

Domanda 12: Trade-off Privacy-Utilità. KL e JS

Discutere il trade-off tra privacy e utilità dei dati, con riferimento alle divergenze KL e JS.

Il trade-off fondamentale: più si protegge la privacy di un dataset, meno informazioni utili rimangono. Non è possibile avere allo stesso tempo massima privacy e massima utilità.

Nel ciclo SDC: Data $\rightarrow$ Metodo SDC $\rightarrow$ Misura di Utilità + Misura di Rischio $\rightarrow$ iterazione. Si cerca un punto di compromesso: i dati rilasciati hanno rischio di disclosure accettabile con massima utilità residua.

Misure di utilità per macrodata: numero di soppressioni, somma delle distanze tra valori veri e perturbati.

Misure di utilità per microdata: quanto l'SDC ha cambiato l'output delle analisi; statistiche di base (medie, varianze, covarianze); **divergenze KL e JS**.

Kullback-Leibler (KL) Divergence

Misura quanto la distribuzione perturbata $P(x)$ è diversa da quella originale $Q(x)$:

$$KL(P\|Q) = \sum_{x \in X} P(x) \log \left(\frac{P(x)}{Q(x)} \right)$$

Proprietà: $KL(P\|Q) \geq 0$; $KL(P\|Q) = 0$ iff $P = Q$; **non è simmetrica**.

Jensen-Shannon (JS) Divergence

Versione simmetrica e smoothed di KL:

$$JS(P\|Q) = \frac{1}{2}KL(P\|M) + \frac{1}{2}KL(Q\|M), \quad M = \frac{P+Q}{2}$$

Proprietà: simmetrica ($JS(P\|Q) = JS(Q\|P)$); $0 \leq JS \leq 1$; sempre definita (nessun problema con probabilità zero).

Utilizzo nel trade-off: KL/JS misurano quanto la distribuzione dei dati protetti si discosta da quella originale. Un $JS \approx 0$ indica alta utilità (le distribuzioni sono simili); un $JS \approx 1$ indica bassa utilità.

Nella Differential Privacy: il Meccanismo di Laplace aggiunge rumore calibrato a GS/ϵ . Maggiore è il rumore (piccolo ϵ), maggiore la privacy ma minore l'utilità.

12 Uso di XML per RBAC e ABAC

Domanda 13: Uso di XML per RBAC e ABAC

Come si usano XML e XACML per implementare il controllo degli accessi RBAC e ABAC?

RBAC (Role Based Access Control, NIST 1992): gestione dell'accesso tramite ruoli. Gli amministratori assegnano permessi ai ruoli; i ruoli vengono assegnati agli utenti. **Limite:** non cattura il contesto (scope, finalità, ambiente).

ABAC (Attribute Based Access Control): evoluzione di RBAC. Le decisioni si basano su attributi di soggetto (chi è), oggetto (a cosa accede), e ambiente (quando, dove, come). Approccio policy-driven.

XACML (eXtensible Access Control Markup Language): standard XML per esprimere policy di accesso in ABAC.

Architettura ABAC con XACML:

- **PEP** (Policy Enforcement Point): riceve la richiesta di accesso e la invia al PDP.
- **PDP** (Policy Decision Point): valuta le policy XACML e decide (Permit/Deny).
- **PAP** (Policy Administration Point): amministra e archivia le policy.
- **PIP** (Policy Information Point): recupera attributi aggiuntivi necessari per la valutazione.

Algoritmi di combinazione in XACML:

- **Permit-overrides:** se almeno una policy dice Permit $\Rightarrow$ risultato = Permit.
- **Deny-overrides:** se almeno una policy dice Deny $\Rightarrow$ risultato = Deny (più restrittivo).

Crittografia su Colonne (complemento al controllo degli accessi): cifra i dati a livello di colonna nel database.

- *Column encryption keys*: cifrare il dato.
- *Column master keys*: cifrare le encryption keys (in repository esterno).
- *Deterministica*: stessa chiave → stesso ciphertext (permette ricerche, meno sicura).
- *Randomizzata*: valori casuali (più sicura, impedisce ricerche dirette).

13 Privacy by Design e by Default

Domanda 15: Privacy by Design e by Default

Descrivere la Privacy by Design e by Default: concetto, origini, principi fondamentali.

Privacy by Design è un approccio proposto da **Ann Cavoukian** (2012), Commissaria per l'Informazione e la Privacy dell'Ontario, Canada. L'idea di base: la privacy non deve essere aggiunta a posteriori ai sistemi, ma deve essere **progettata e incorporata fin dall'inizio**.

Il GDPR (Art. 25) rende la Privacy by Design e by Default un **obbligo legale**.

7 Principi Fondamentali:

1. **Proattività, non reattività – Prevenzione, non rimedio**: anticipare e prevenire i problemi prima che si verifichino. Non aspettare le violazioni.
2. **Privacy come impostazione di Default**: senza azioni da parte dell'utente, le impostazioni più privacy-preserving devono essere quelle default. "Opt-out", non "opt-in".
3. **Privacy integrata nel Design**: la privacy fa parte integrante dell'architettura del sistema e dei processi di business, non è un'aggiunta.
4. **Full Functionality – positive-sum, non zero-sum**: privacy e funzionalità non si escludono mutualmente. Entrambe possono essere ottenute allo stesso tempo.
5. **End-to-end Security – protezione dell'intero ciclo di vita**: la sicurezza dei dati deve essere garantita dall'acquisizione alla cancellazione.
6. **Visibilità e Trasparenza – Keep it Open**: tutte le attività di trattamento devono essere visibili e verificabili da utenti e regolatori.
7. **Rispetto per la Privacy degli Utenti – Keep it User-Centric**: l'utente al centro. Le decisioni devono tenere conto delle sue preferenze e aspettative.

Privacy by Default nel GDPR:

- Raccogliere solo i dati strettamente necessari per ogni scopo specifico.
- Conservare i dati solo per il tempo necessario.
- Rendere i dati accessibili solo alle persone necessarie.

Responsibility e Accountability: il titolare del trattamento deve non solo rispettare la privacy, ma anche essere in grado di **dimostrare** la compliance. Questo include: mantenere registri delle attività di trattamento, condurre DPIA per trattamenti ad alto rischio, nominare un DPO quando necessario.

14 Cambridge Analytica

Domanda 16: Cambridge Analytica

Descrivere il caso Cambridge Analytica come esempio di uso dei dati per finalità diverse da quelle originarie.

Il caso Cambridge Analytica (2016–2018) è l'esempio paradigmatico di violazione del principio di *scopo legittimo*: dati raccolti per una finalità (divertimento, ricerca accademica) usati per un'altra (manipolazione politica).

Cronologia:

1. **2014**: Aleksandr Kogan, ricercatore dell'Università di Cambridge, crea un'app-quiz ("thisisyourdigitallife"). Circa 270.000 utenti la installano dando consenso a raccogliere i propri dati Facebook.
2. **API di Facebook (pre-2015)**: permetteva agli sviluppatori di accedere non solo ai dati degli utenti dell'app, ma anche a quelli dei loro **amici** senza consenso esplicito.
3. Risultato: Kogan raccoglie dati di circa **87 milioni di utenti** Facebook.
4. Kogan vende i dati a Cambridge Analytica (violando i termini di servizio di Facebook).
5. Cambridge Analytica usa i dati per costruire **profili psicologici** (basati sul modello OCEAN/Big Five) e mirare messaggi politici personalizzati.
6. I profili vengono usati nelle campagne di Donald Trump (2016) e nel referendum Brexit (2016).

Perché è possibile? – Studio PNAS 2013 (Kosinski et al.): analizzando i "Like" su Facebook con SVD + regressione logistica si può predire: orientamento sessuale (88% accuratezza), etnia (95%), opinioni politiche (85%), religione (82%), stato relazionale, uso di droghe. I "proxy attributes" (like a band, film) rivelano informazioni altamente sensibili.

Violazioni principali:

- **Scopo legittimo**: i dati raccolti per la ricerca usati per finalità politiche/commerciali.
- **Trasparenza e consenso**: nessun consenso degli 87 milioni; violazione dei ToS di Facebook.
- **Proporzionalità**: raccolta eccessiva di dati (dati degli amici senza consenso).

Conseguenze: sanzione di \$5 miliardi a Facebook dalla FTC; rafforzamento del GDPR; chiusura di Cambridge Analytica nel 2018.

Lezione: il principio del "nulla da nascondere" è ingenuo; dati apparentemente innocui (like musicali) possono essere usati per manipolazione su larga scala.

15 Principi Crittografici nel Corso

Domanda 17: Principi Crittografici durante il Corso

Descrivere i principi crittografici trattati nel corso.

1. Crittografia a Chiave Pubblica (RSA):

- Ogni utente ha una coppia di chiavi: **pubblica** (per cifrare) e **privata** (per decifrare).
- Basata sulla difficoltà di fattorizzare il prodotto di due numeri primi grandi.

- Chiunque può cifrare con la chiave pubblica; solo il possessore della privata può decifrare.
- Usa anche un sistema di padding per sicurezza.

2. Crittografia su Colonne (Column-Level Encryption):

- Column encryption keys (per i dati) + Column master keys (per le encryption keys, conservate esternamente).
- Deterministica vs. randomizzata.
- TDE (Oracle): Transparent Data Encryption con Oracle Wallet come repository esterno.

3. Oblivious Transfer (OT) – Principio Crittografico per SMC:

- OT 1-of-2: il receiver ottiene esattamente uno dei due messaggi del sender; il sender non sa quale.
- OT 1-of-N: estensione usando funzioni pseudo-randomiche.
- Oblivious Polynomial Evaluation: il receiver ottiene $Q(z)$ senza che il sender sappia z .

4. Garbled Circuit (Yao):

- Tecnica per eseguire funzioni arbitrarie in modo sicuro tra due parti.
- Le tavole di verità dei gate del circuito sono cifrate (“garbled”).
- Il receiver valuta il circuito senza vedere i valori intermedi.

5. Crittografia Funzionale:

- Generalizzazione della crittografia a chiave pubblica.
- Decifrare rivela solo una funzione del plaintext (es. “è maggiore di 30?”).

6. Crittografia Omomorfica:

- Permette di effettuare calcoli sui dati cifrati senza decifrarli.
- I risultati sono in forma cifrata e decifrando si ottiene il risultato delle operazioni.
- Computazionalmente molto costosa.

7. Pseudoanonimizzazione:

- Sostituzione di informazioni identificabili con pseudonimi.
- Reversibile (con la chiave/tabella di mapping).
- Diversa dall’anonimizzazione totale.

16 L-Diversity e Differential Privacy

Domanda 18: L-Diversity e Differential Privacy

Confrontare la l-diversity con la differential privacy come protezioni contro gli attacchi alla k-anonymity.

Contesto: la k-anonymity non protegge contro homogeneity attack e background knowledge attack.

L-Diversity (Machanavajjhala et al., 2006): richiede che ogni q^* -block (classe di equivalenza) contenga almeno $l \geq 2$ valori sensibili *ben rappresentati*.

Formulazione tramite entropia:

$$-\sum_{s \in S} p(q^*, s) \log(p(q^*, s)) \geq \log(l)$$

Vantaggi: semplice da capire; soddisfa proprietà di monotonicità (compatibile con gli algoritmi per la k-anonymity).

Limiti della l-diversity:

- **Skewness attack:** se un valore sensibile è molto più comune nella popolazione, la sua presenza in un blocco l-diverso non protegge.
- **Similarity attack:** valori semanticamente simili (diversi tipi di cancro) non proteggono anche se formalmente diversi.
- Non modella esplicitamente la conoscenza dell'avversario.

Differential Privacy (Dwork, 2006): approccio fondamentalmente diverso.

Confronto:

Aspetto	L-Diversity	Differential Privacy
Tipo	Non-perturbativa o perturbativa	Perturbativa (rumore)
Garanzia	Per-block	Su tutto il dataset
Modello avversario	Implicito	Esplicito (qualsiasi KB)
Misurabilità	Parametro l	Parametro ϵ
Trade-off	Generalizzazione	Rumore
Robustezza	Limitata	Massima (teorema)

La DP offre garanzie molto più forti: indipendente dalla conoscenza pregressa dell'avversario; modello matematicamente rigoroso; garantisce che la risposta alla query non riveli più di quanto l'avversario già sapesse.

Oggi: la DP ha sostanzialmente rimpiazzato la l-diversity e la k-anonymity per la protezione di dati statistici. La k-anonymity rimane rilevante per la pubblicazione di microdata (non query).

17 Multiparty Secure Computation: Milionari, OT, ID3

Domanda 19 & 21: Multiparty Secure Computation: Milionari, Oblivious Transfer, ID3

Descrivere i protocolli di Secure Multiparty Computation trattati nel corso.

Problema: si vuole effettuare un'analisi congiunta su dati distribuiti tra parti che non si fidano l'una dell'altra.

SMC (Secure Multiparty Computation): calcolare una funzione quando ogni parte ha qualche input, senza che nessuna parte impari più di quanto l'output permette di inferire.

Il Problema dei Milionari (Yao)

Alice e Bob vogliono sapere chi è più ricco senza rivelare il proprio patrimonio.

Soluzione con Garbled Circuit:

1. Alice (garbler) crea un garbled circuit per la funzione di confronto $A > B$.
2. Alice invia il garbled circuit a Bob insieme ai garbled values corrispondenti al suo input A .
3. Bob usa **Oblivious Transfer** per ottenere i garbled values del suo input B senza che Alice sappia B .
4. Bob valuta il garbled circuit: solo l'output finale è rivelato.

La funzione di confronto binario si implementa con il circuito: $(A \oplus B) \cdot A$. XOR gate: calcolato localmente (gratuito). AND gate: tramite OT table.

Overhead: $O(\text{dimensione del circuito}) + O(|y|)$ OT. Solo 2 round di comunicazione.

Oblivious Transfer (OT)

OT 1-of-2: sender ha (x_0, x_1) ; receiver ha $\sigma \in \{0, 1\}$. Proprietà: receiver impara x_σ e niente altro; sender non impara σ .

OT 1-of-N: estensione tramite funzioni pseudo-randomiche: $c_{ij} = F_{k'_i}(ij) \oplus F_{k_j}(ij) \oplus m_{ij}$.

Oblivious Polynomial Evaluation: sender ha polinomio Q di grado k ; receiver ha z ; receiver ottiene $Q(z)$. Il sender non sa z ; il receiver non sa i coefficienti. Overhead: $O(k)$ esponenziali.

Privacy Preserving ID3 (Lindell & Pinkas, 2002)

ID3 Algorithm: costruisce un decision tree tramite information gain. Iterativamente seleziona l'attributo con massimo guadagno di informazione.

ID3_δ: protocollo per ID3 su dati orizzontalmente distribuiti tra due parti (semi-honest model).

Tre passi principali per costruire il decision tree:

1. **Classe più frequente:** calcolata con il protocollo di Yao (circuiti per trovare il massimo); necessario per decidere se creare una foglia.
2. **Verifica foglia (leaf check):** tramite protocollo di uguaglianza (ogni parte conta i propri record per ciascuna classe; si verifica se tutte le tuple appartengono alla stessa classe).
3. **Selezione del miglior attributo:** calcola $x \ln x$ per ogni valore dell'attributo usando una serie di Taylor: $\ln(1 + \varepsilon) \approx \varepsilon - \varepsilon^2/2 + \varepsilon^3/3 - \dots$; permette di calcolare l'entropia e il guadagno di informazione in modo privato.

Sicurezza del protocollo OT:

- Per il sender: un receiver corrotto non impara informazioni aggiuntive diverse dal messaggio che ha dichiarato di voler leggere.
- Per il receiver: un sender corrotto non impara nulla sul receiver.

Altri approcci per dati distribuiti:

- **Functional Encryption:** decifrare rivela solo $f(\text{plaintext})$.
- **Homomorphic Encryption:** calcoli su dati cifrati.
- **Federated Learning:** allenamento distribuito; solo i gradienti/parametri vengono condivisi, non i dati grezzi.

18 Bias: Rischi Etici e Misurazione (Fairness)

Domanda 22: Bias – Rischi Etici e Misurazione (Fairness)

Descrivere i rischi etici del bias algoritmico e i metodi per misurare la fairness.

Rischi Etici del Bias:

1. **Danni Allocativi:** risorse o opportunità vengono negate in modo disparato.

- **COMPAS:** punteggi di rischio di recidiva più alti per afroamericani $\Rightarrow$ detenzione preventiva ingiustificata.
- **Amazon:** modello di selezione del personale che discrimina le donne.
- **Credito:** algoritmi che negano prestiti a minoranze etniche.
- **Sanità:** algoritmi che allocano meno risorse sanitarie a certi gruppi.

2. **Danni Rappresentativi:** subordinazione e stereotipi rafforzati.

- **Ricerca di immagini:** ricerche come “professore” mostrano principalmente uomini bianchi.
- **Traduzione automatica:** introduzione di stereotipi di genere.
- **Riconoscimento facciale:** errori più frequenti per donne e persone di colore.

3. **Erosione della fiducia:** se i sistemi automatici sono percepiti come ingiusti, si riduce la fiducia nelle istituzioni che li usano.

4. **Effetti di feedback:** un sistema discriminatorio crea dati futuri che confermano la discriminazione (bias self-reinforcing).

5. **Mancanza di trasparenza:** i sistemi ML complessi (deep learning) sono difficili da interpretare; è difficile identificare e correggere il bias.

Misure di Fairness:

Siano A = attributo sensibile, Y = valore reale (ground truth), $\hat{Y}$ = previsione del classificatore.

Indipendenza (Demographic Parity): $\hat{Y} \perp A$

$$P(\hat{Y} = 1|A = a) = P(\hat{Y} = 1|A = b)$$

Ogni gruppo riceve la stessa percentuale di esiti positivi. **Limite:** può essere soddisfatta con meccanismi ingiusti.

Separazione (Equal Error Rates): $\hat{Y} \perp A | Y$

Parità del tasso di errore: il classificatore commette errori ugualmente frequenti in tutti i gruppi. Equivalente a:

- Equal True Positive Rate (TPR).
- Equal False Positive Rate (FPR).

Sufficienza (Calibration): $Y \perp A | \hat{Y}$

La previsione del modello ha lo stesso significato predittivo per tutti i gruppi.

Teoremi di Incompatibilità: se A e Y non sono indipendenti, **separazione e indipendenza** non possono essere entrambe soddisfatte; né **sufficienza e indipendenza**. La scelta del criterio di fairness dipende dal contesto etico.

Interventi di Fairness:

- **Pre-processing:** rimozione o de-biasing dei dati (soppressione di attributi proxy, re-weighting).
- **In-processing:** aggiungere vincoli di fairness durante il training (penalizzazioni nella funzione di loss).
- **Post-processing:** modificare le predizioni $\hat{Y}$ per soddisfare vincoli di fairness.

Ruolo dell'egalitarismo: da una prospettiva etica, le ineguaglianze dovute alla *fortuna* (nascere in un certo gruppo) dovrebbero essere corrette; quelle dovute al *merito* possono essere accettate. Ma distinguere fortuna da merito è difficile, e l'inconsapevolezza pura nei modelli ML è praticamente impossibile da garantire.